

PASTA exercício

Etapas	Empresa de tênis
I. Definir objetivos de negócios e segurança	Requisitos específicos do negócio que serão analisados. • <i>O aplicativo deve processar transações financeiras.</i> • <i>Os usuários podem criar perfis de membros internamente ou conectando contas externas.</i> • <i>O aplicativo deve estar em conformidade com o PCI-DSS.</i>
II. Definir o escopo técnico	Lista de tecnologias utilizadas pela aplicação: • <i>Application programming interface (API)</i> • <i>Public key infrastructure (PKI)</i> • <i>SHA-256</i> • <i>SQL</i> As APIs facilitam a troca de dados entre clientes, parceiros e funcionários, portanto, devem ser priorizadas. Elas lidam com muitos dados sensíveis enquanto conectam vários usuários e sistemas. No entanto, detalhes como quais APIs estão sendo usadas devem ser considerados antes de priorizar uma tecnologia em detrimento de outra. Assim, elas podem ser mais propensas a vulnerabilidades de segurança, pois possuem uma superfície de ataque maior.
III. Decompor aplicação	Exemplo de diagrama de fluxo de dados
IV. Análise de ameaças	Riscos para as informações que estão sendo processadas pelo aplicativo. • <i>SQL injection ou XSS</i> • <i>Sequestro de sessão</i>
V. Análise de vulnerabilidade	Vulnerabilidades que poderiam ser exploradas. • <i>Falta de declarações preparadas</i> • <i>Token de API corrompido</i>
VI. Modelagem de ataques	Exemplo de diagrama de árvore de ataque

VII. Análise e impacto do risco	Controles de segurança que podem reduzir o risco. • SHA-256 + Salt • Procedimentos de resposta a incidentes • Política de senhas • Princípio do menor privilégio
--	---
